Chapter 2: Physical Security

Section 2.2 – Locks and Keys

Is Physical Security An IT Concern?

- You have been working hard to secure your network from cyber attacks
- But what if an attacker gains access to the server room or network wiring closet …
  - Is you network still safe?
- Attackers could use ‘side-channel attack’ to facilitate cyber-attack:
  - Use keyboard sound to know key strokes
  - Use computer screen light change to detect information
  - Attach USB key to spy/record

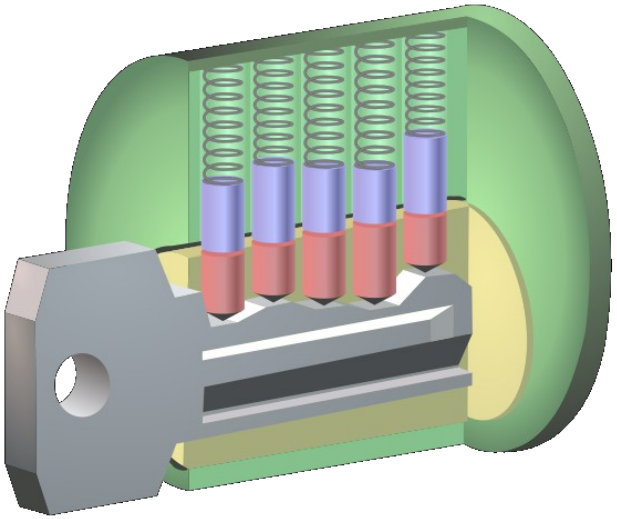
Compromising Locks

- For centuries, the lock has been one of the cornerstones of physical security
  - We rely on dozens of them every day to protect people and assets
- The trust most people place in locks is unwarranted
  - Most locks can be easily compromised with nondestructive methods
  - Sometimes within seconds and with readily available tools

1860: Yale Pin Tumbler Lock



- Modern version of the Egyptian single-pin design
- Utilizes two pins for locking

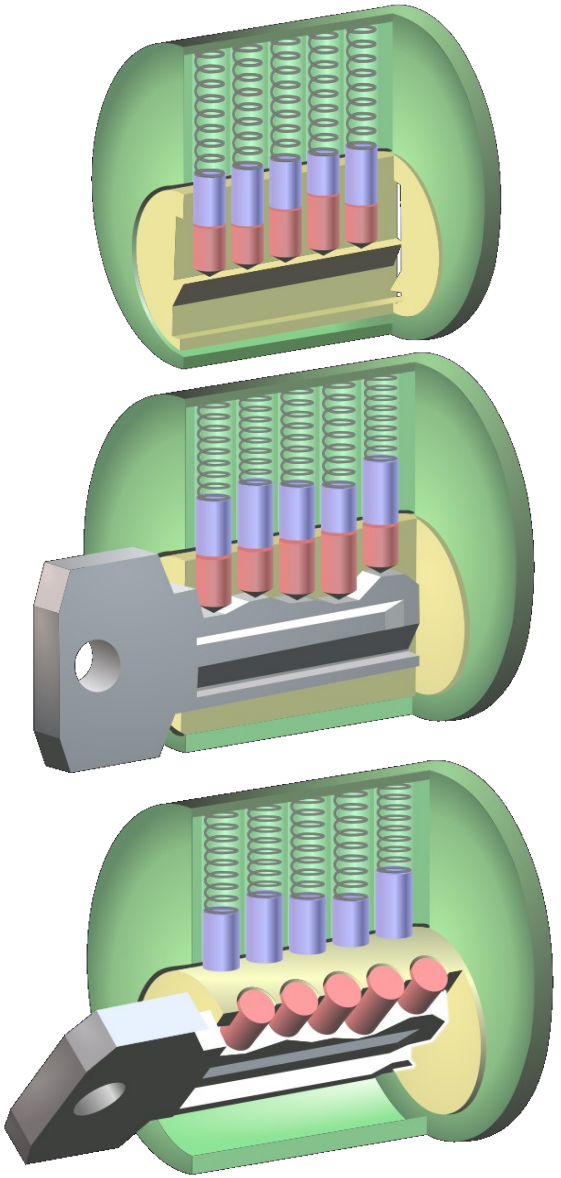


- Double-detainer theory of locking
- Created shear line
- Link

https://youtu.be/smIdInCQ-kU?si=F_ktgTjJJ3bUSGGe

How Does a Pin Tumbler Lock Work?

1. When a key is not present, the pin stacks are pushed down by the springs so that the driver (top) pins span the plug and the outer casing, preventing the plug from rotating.
2. When the correct key is inserted, the ridges of the key push up the pin stacks so that the cuts of the pin stacks are aligned with the shear line.
3. The alignment of the cuts with the shear line allows the plug to be rotated.



Images from http://en.wikipedia.org/wiki/File:Pin_tumbler_with_key.svg used with permission under Gnu Free Documentation License 1.2

How Does a Pin Tumbler Lock Work?

- If an inappropriate key is insered, then the pins do not align along the shear line and the lock does not turn.

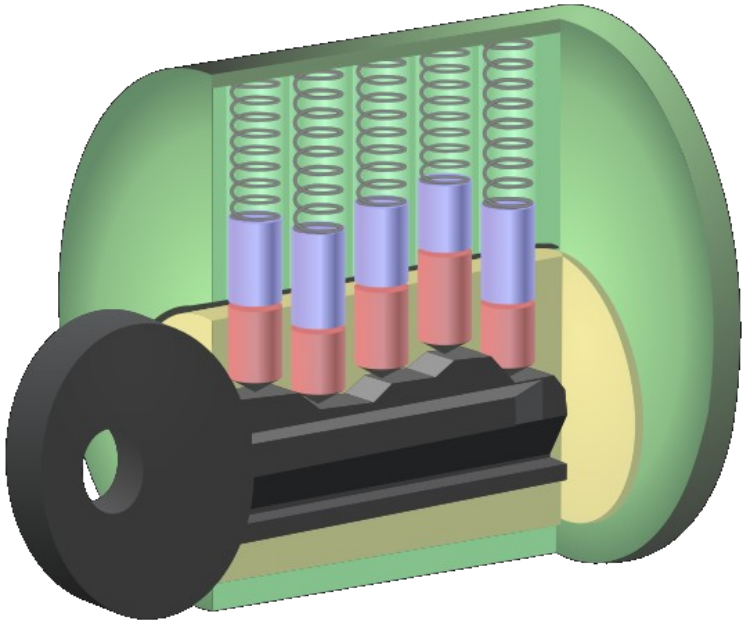
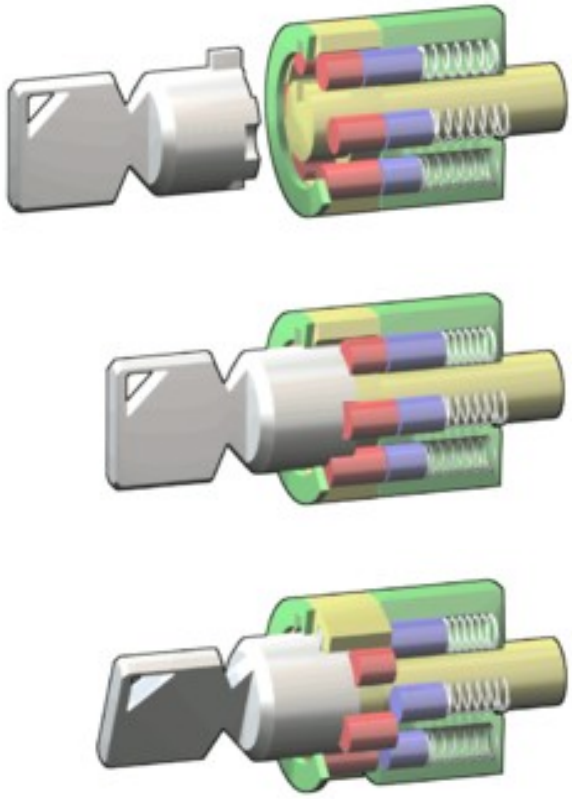


Image from http://en.wikipedia.org/wiki/File:Pin_tumbler_with_key.svg used with permission under Gnu Free Documentation License 1.2

Tubular lock

- Usually on car alarms or vending machines
- 6-8 pins
- Easy to pick with special tool
- The tool could become a new key

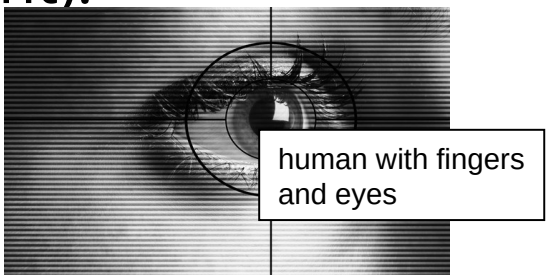


Images from http://en.wikipedia.org/wiki/File:Tubular_locked.png used with permission under Gnu Free Documentation License 1.2

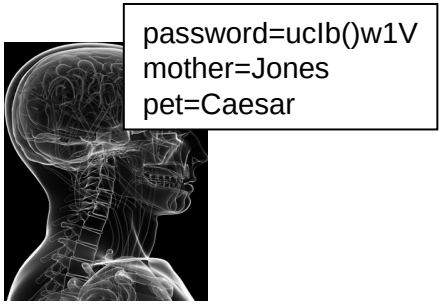
Section 2.3 – Authentication Technologies

Authentication

- The determination of **identity**, usually based on a combination of
  - something the person has (like a smart card or a radio key fob storing secret keys),
  - something the person knows (like a password),
  - something the person is (like a human with a fingerprint).



Something you are



Something you know



Something you have

Barcodes

- Developed in the 20th century to improve efficiency in grocery checkout



- First-generation barcodes represent data as a series of **variable-width, vertical lines** of ink, which is essentially a one-dimensional encoding scheme.
- Some more recent barcodes are rendered as **two-dimensional patterns** using dots, squares, or other symbols that can be read by specialized optical scanners, which translate a specific type of barcode into its encoded information.



QR Code

- 2D, machine-readable barcode.
- Scanned with a smartphone cam
- Acts as a shortcut to
  - instantly open a website,
  - display digital menus,
  - download apps,
  - process payments, or
  - connect to Wi-Fi

  without manual typing

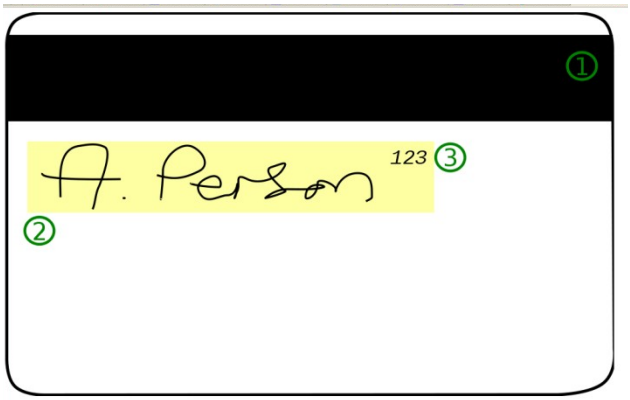


Bar Code vs. QR code

Feature	Standard Barcode (1D)	QR Code (2D)
Shape	Linear (parallel vertical lines)	Square grid pattern
Data Capacity	Low (8–20 characters, mostly numbers)	High (Up to 4,296 alphanumeric characters)
Information Stored	Product IDs, serial numbers	URLs, UPI payments, text, contact info
Scanning	Laser scanners or imagers; requires horizontal line of sight	Smartphone cameras or QR apps; omnidirectional scanning
Damage Resilience	Low (tears or smudges break the code)	High (built-in error correction, readable if 30% damaged)

Magnetic Stripe Cards

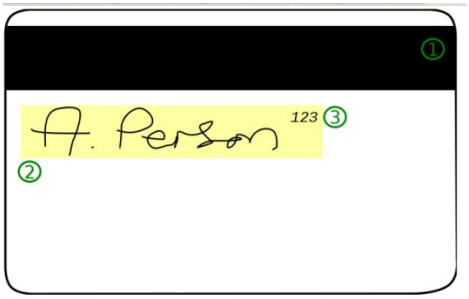
- Plastic card with a magnetic stripe containing personalized information about the card holder.
- The first track of a magnetic stripe card contains the cardholder's full name in addition to an account number, format information, and other data.
- The second track may contain the account number, expiration date, information about the issuing bank, data specifying the exact format of the track, and other discretionary data.



Public domain image by *Alexander Jones* from http://commons.wikimedia.org/wiki/File:CCardBack.svg

Magnetic Stripe Card Security

- One vulnerability of the magnetic stripe medium is that it is easy to read and reproduce.
- Magnetic stripe readers can be purchased at relatively low cost, allowing attackers to read information off cards.
  - When coupled with a magnetic stripe writer, which is only a little more expensive, an attacker can easily clone existing cards.
- So, many uses require card holders to enter a PIN to use their cards
  - Even for credit cards, many require input your zip code



Public domain image by *Alexander Jones* from http://commons.wikimedia.org/wiki/File:CCardBack.svg

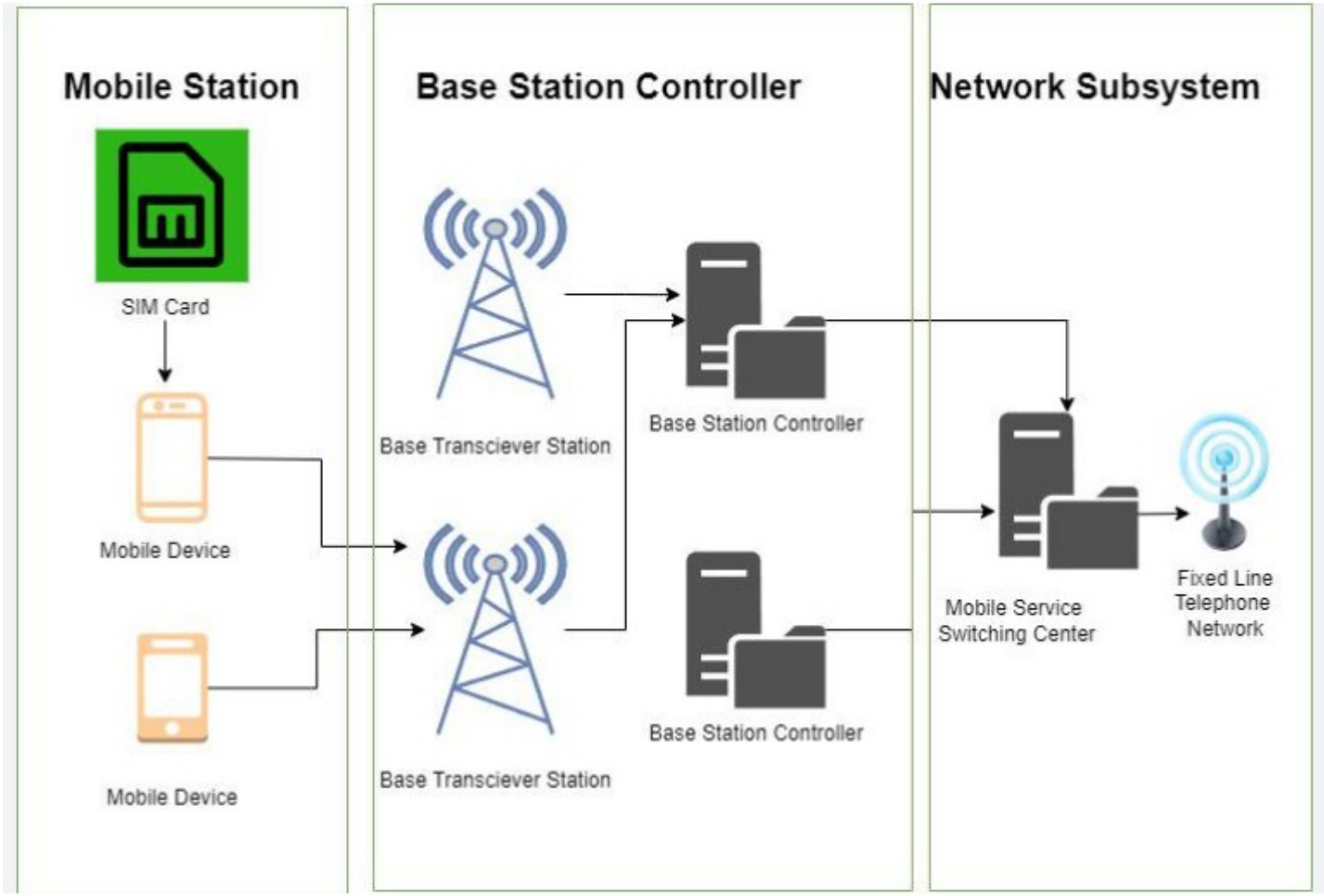
Smart Cards

- **Smart cards** incorporate an integrated circuit, optionally with an on-board microprocessor (for computing, encryption, decryption), allowing the data on the card to be accessed/altered
  - Can provide secure authentication mechanisms that protect the information of the owner and are difficult to duplicate.
  - May be used as "electronic wallet," with funds for various services transactions
    - It means each transaction does not go through bank account

Circuit interface



GSM network

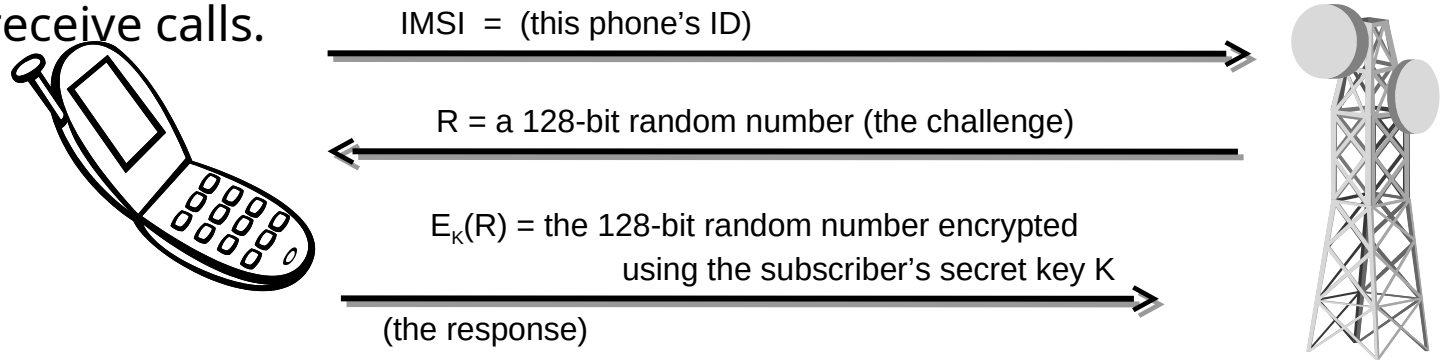

Mobile Station
Base Station Controller
Network Subsystem
SIM Card
Mobile Device
Mobile Device
Base Transciever Station
Base Transciever Station
Base Station Controller
Base Station Controller
Mobile Service Switching Center
Fixed Line Telephone Network

SIM Card and its Security

- Many mobile phones use a special smart card called a **subscriber identity module card (SIM card).**
  - SIM card maintains personal information for a user and allows the user to authenticate to the cellular network of the provider.
  - Each SIM card corresponds to a record in the database of subscribers maintained by the network provider.
- A SIM card has a unique hardware 18-bit **integrated circuit card ID (ICCID)**
- Next, a SIM card contains a unique **international mobile subscriber identity** (**IMSI**)**,** which identifies the owner's country, network, and personal identity.
- SIM cards also contain a 128-bit **secret key.** This key is used for authenticating a phone to a mobile network.

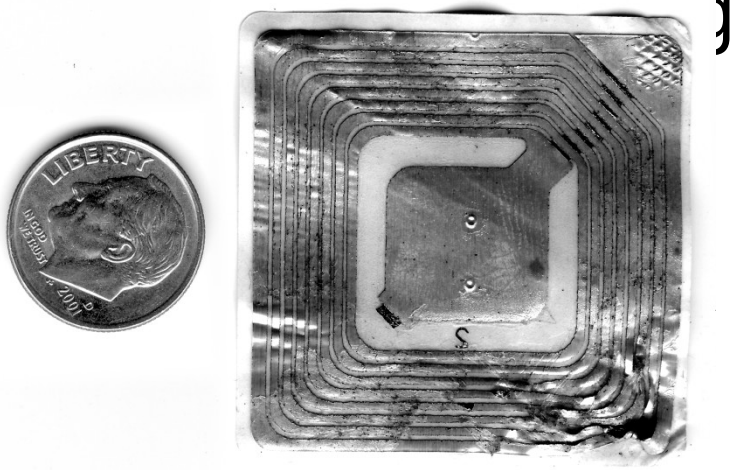
GSM Challenge-Response Protocol

1. When a cellphone wishes to join a cellular network it connects to a local **base station** owned by the network provider and transmits its IMSI.
2. If the IMSI matches a subscriber's record in the network provider's database, the base station transmits a 128-bit random number to the cellphone.
3. This random number is then encoded by the cellphone with the subscriber's secret key stored in the SIM card using a proprietary encryption algorithm known as **A3,** resulting in a ciphertext that is sent back to the base station**.**
4. The base station then performs the same computation, using its stored value for the subscriber's secret key. If the two ciphertexts match, the cellphone is authenticated to the network and is allowed to make and receive calls.



RFIDs

- **Radio frequency identification, or RFID,** is a rapidly emerging technology that relies on small transponders to transmit identification information via radio waves.
- RFID chips feature an integrated circuit for storing information, and a coiled antenna to transmit a [illegible]gnal.



RFID Technology

- RFID tags must be used in conjunction with a separate reader or writer.
- While some RFID tags require a battery, many are passive and do not.
- The effective range of RFID varies from a few centimeters to several meters,
  - Not necessary for a tag to be in the line of sight of the reader

RFID Technology Applications

- Expensive product anti-theft ID (like a barcode)
- Car key fobs (speedpass)
- Electronic toll transponders
  - Active one (need battery)
  - Passive one (more convenient, but need powerful reader)



Biometrics

- **Biometric** refers to any measure used to uniquely identify a person based on biological or physiological traits.

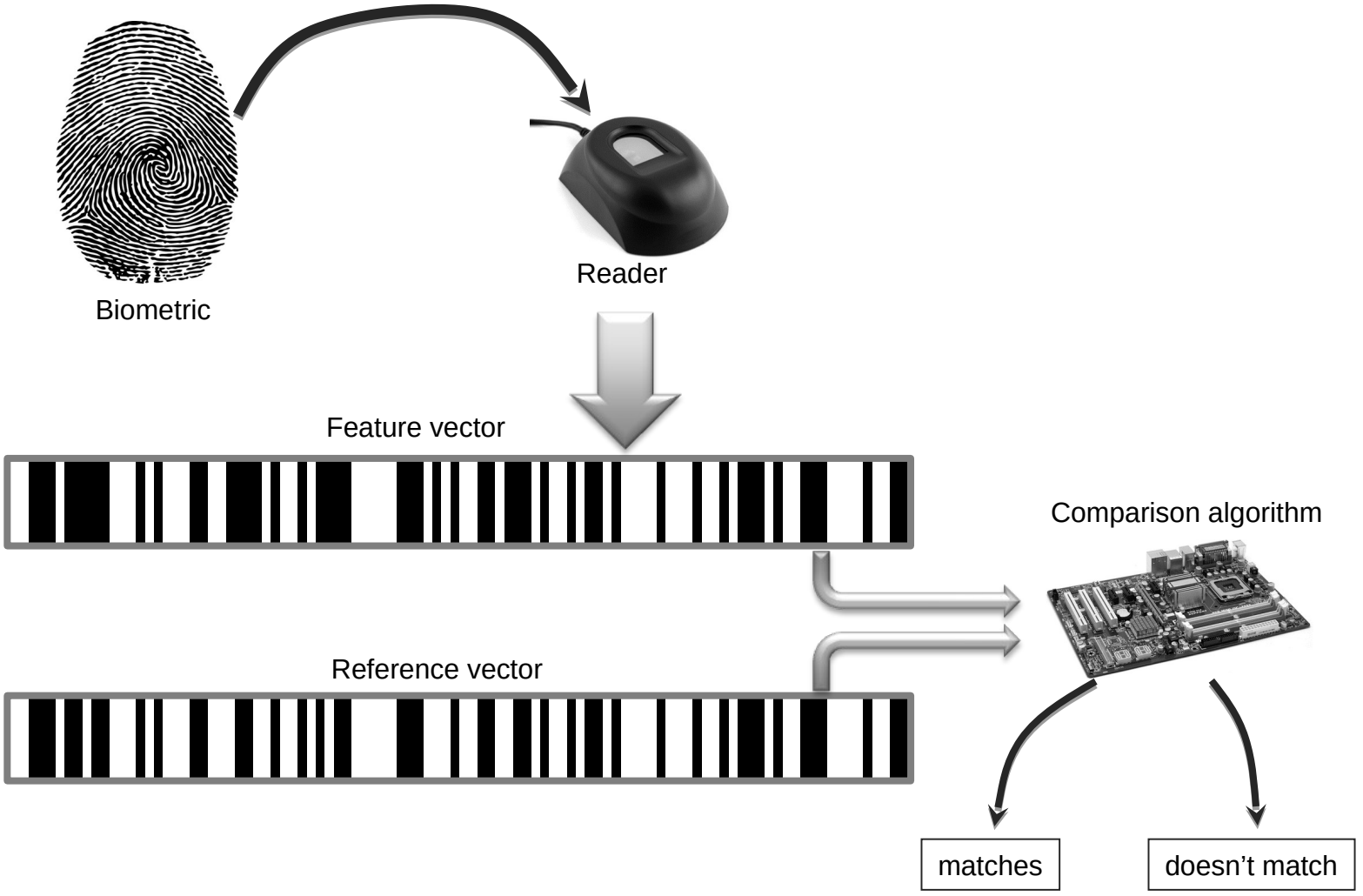


Image from http://commons.wikimedia.org/wiki/File:Fingerprint_scanner_in_Tel_Aviv.jpg used with permission under the Creative Commons Attribution 3.0 Unported license

Requirements for Biometric Identification

- **Universality.** Almost every person should have this characteristic.
- **Distinctiveness.** Each person should have noticeable differences in the characteristic.
- **Permanence.** The characteristic should not change significantly over time.
- **Collectability.** The characteristic should have the ability to be effectively determined and quantified.

Biometric Identification



Candidates for Biometric IDs

- Fingerprints
- Retinal/iris scans
- DNA
- “Blue-ink” signature
- Voice recognition
- Face recognition
- Gait recognition



Public domain image from
http://commons.wikimedia.org/wiki/File:Fingerprint_Arch.jpg



Public domain image from
http://commons.wikimedia.org/wiki/File:Retinal_scan_securimetrics.jpg



Public domain image from
http://commons.wikimedia.org/wiki/File:CBP_chemist_reads_a_DNA_profile.jpg



Security and Privacy Concerns for Biometric Data

- A person's biometric data is permanent
  - One-time leak results in compromising forever
  - Will reveal private information of the person
- Saving hash value is not practical since bio-data allows small variations

Section 2.4 – Direct Attacks on Computational Devices

Eavesdropping

- **Eavesdropping** is the process of secretly listening in on another person's conversation.
- Simple eavesdropping techniques include
  - Using social engineering to allow the attacker to read information over the victim's shoulder
  - Installing small cameras to capture the information as it is being read
  - Using binoculars to view a victim's monitor through an open window.

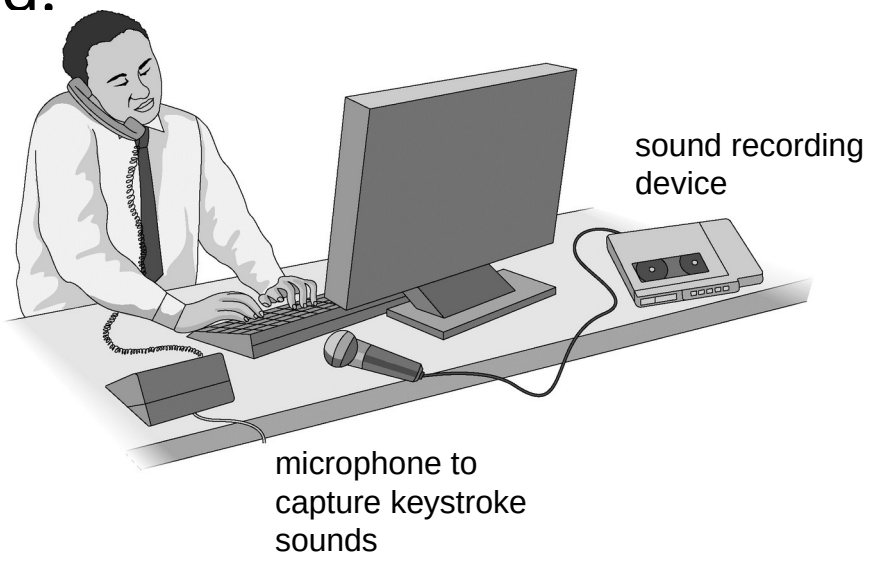
- These direct observation techniques are commonly referred to as **shoulder surfing.**

Signal Emanations

- Computer screens emit **radio frequencies** that can be used to detect what is being displayed.
- **Visible light** reflections can also be used to reconstruct a display from its reflection on a wall, coffee mug, or eyeglasses.
- Both of these require the attacker to have a receiver close enough to detect the signal.

Acoustic Emissions

- Dmitri Asonov and Rakesh Agrawal published a paper in 2004 detailing how an attacker could use an audio recording of a user typing on a keyboard to reconstruct what was typed.
  - Each keystroke has minute differences in the sound it produces, and certain keys are known to be pressed more often than others.
  - After training an advanced neural network to recognize individual keys, their software recognized an average 79% of all keystrokes.



Dmitri Asonov, Rakesh Agrawal: "Keyboard Acoustic Emanations",
IEEE Symposium on Security and Privacy, Oakland, California, May 2004.

Hardware Keyloggers

- A keylogger is any means of recording a victim's keystrokes, typically used to eavesdrop passwords or other sensitive information.
- For example, a USB keylogger is a device containing male and female USB connectors, which allow it to be placed between a USB port on a computer and a USB cable coming from a keyboard.
  - Attackers can secretly get in, plug in, get it out later.

